

Rapport de Test d'Intrusion et d'Audit de Sécurité Environnement Backend — Traitement des données Facebook Login

Scope : API REST, authentification, base de données, endpoints Facebook Login Exécuté par : Équipe technique BantuDelice Date du test : 3 juin 2026

1. RÉSUMÉ EXÉCUTIF

Un audit de sécurité complet a été réalisé sur l'environnement backend de BantuDelice entre le 15 avril et le 2 juin 2026. L'objectif principal était d'identifier toute vulnérabilité susceptible d'entraîner un accès non autorisé aux données des utilisateurs, en particulier les données transmises via l'intégration Facebook Login (Meta).

Au total, **9 vulnérabilités** ont été identifiées : **0 critique**, **2 élevées**, **4 moyennes** et **3 faibles**. Les 2 vulnérabilités élevées ont été **corrigées intégralement** avant la publication de ce rapport. Aucune vulnérabilité en cours ne présente de risque d'accès non autorisé aux données de la plateforme Facebook.

0
CRITIQUE

2
ÉLEVÉ

4
MOYEN

3
FAIBLE

9
TOTAL

Statut	Critique	Élevé	Moyen	Faible
Corrigé	0	2	2	1
En cours / Planifié	0	0	2	2

Conclusion : Aucune vulnérabilité critique ou élevée non corrigée. Les 4 éléments restants (2 moyens, 2 faibles) ne permettent pas d'accès non autorisé aux données de la plateforme Facebook Login et ont un plan de correction planifié.

2. PÉRIMÈTRE ET MÉTHODOLOGIE

2.1 Périmètre du test

- **Application web** : <https://bantudelice.cg> — routes publiques et authentifiées
- **API REST** : Endpoints d'authentification, gestion des commandes, profils utilisateurs
- **Flux Facebook Login** : Réception du token Meta, validation Graph API, création de session
- **Base de données** : Requêtes ORM Laravel (Eloquent), vérification injection SQL
- **Infrastructure** : Serveur VPS OVH, configuration Nginx, TLS/HTTPS, headers de sécurité
- **Gestion des secrets** : Variables d'environnement, fichiers de configuration

2.2 Méthodologie

Les tests ont suivi le standard **OWASP Testing Guide v4.2** et couvert les catégories OWASP Top 10 2025 :

- **Revue de code statique** : Inspection manuelle du code source Laravel (contrôleurs, middleware, modèles)
- **Tests dynamiques** : Simulation de requêtes malveillantes via Burp Suite Community, curl et scripts Python
- **Audit des configurations** : Headers HTTP, cookies, HTTPS, CORS, rate limiting
- **Tests d'authentification** : Contournement de session, IDOR, vérification des tokens Facebook Login
- **Audit des dépendances** : composer audit — vérification des CVE connues
- **Vérification des secrets** : Absence de credentials dans le dépôt Git, chiffrement en transit

2.3 Outils utilisés

Outil	Usage
Burp Suite Community 2024	Interception et modification de requêtes HTTP, tests d'injection
OWASP ZAP 2.14	Scan automatisé des vulnérabilités web
composer audit	Vérification CVE des dépendances PHP/Laravel
curl / HTTPie	Tests manuels des endpoints API REST
git log / grep	Vérification absence de secrets dans l'historique Git
Mozilla Observatory	Audit des headers de sécurité HTTP

3. VULNÉRABILITÉS IDENTIFIÉES — DÉTAIL

F-001 Insecure Direct Object Reference (IDOR) sur l'endpoint de profil utilisateur ÉLEVÉ ✓ CORRIGÉ

OWASP : A1 — Broken Access Control

CVSS v3.1 : 7.5 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)

Description : Un utilisateur authentifié pouvait accéder aux données de profil d'un autre utilisateur en modifiant l'identifiant numérique dans l'URL (/api/user/{id}/profile) sans vérification de propriété.

Impact : Lecture non autorisée des données personnelles (email, adresse, numéro de téléphone). Applicable aux données de profil liées à un compte Facebook Login.

Correction : Ajout d'une vérification `$request->user()->id === $id` dans le contrôleur. Middleware `auth:api` renforcé pour toutes les routes de profil.

Date correction : 28 avril 2026

Vérification : Re-test effectué le 2 mai 2026 — l'accès inter-utilisateurs retourne désormais HTTP 403.

F-002 Mot de passe base de données en clair dans le script de sauvegarde ÉLEVÉ ✓ CORRIGÉ

OWASP : A2 — Cryptographic Failures

CVSS v3.1 : 7.1 (AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)

Description : Le script de sauvegarde automatique (`scripts/backup_db.sh`) contenait le mot de passe de la base de données MySQL en clair dans la commande `mysqldump -pBantuDb2026!`.

Impact : Exposition du credential MySQL si le script est lu par un utilisateur non autorisé ou loggé dans l'historique `bash/cron`.

Correction : Le script lit désormais le mot de passe depuis le fichier `.env` via `grep "^DB_PASSWORD=" .env | cut -d= -f2`. Aucun credential en clair dans les scripts.

Date correction : 5 mai 2026

F-003 Configuration SMTP en mode log (emails non envoyés en production) MOYEN ✓ CORRIGÉ

OWASP : A5 — Security Misconfiguration

CVSS v3.1 : 5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N)

Description : Le driver d'email était configuré sur `MAIL_MAILER=log` en production, empêchant l'envoi des emails de vérification et de réinitialisation de mot de passe.

Impact : Les utilisateurs ne recevaient pas les emails de confirmation de compte, réduisant la fiabilité de la vérification d'identité.

Correction : Configuré sur `MAIL_MAILER=smtp` avec Brevo (Sendinblue) en production. Emails de vérification fonctionnels.

Date correction : 20 avril 2026

F-004 Absence de rate limiting sur l'endpoint de connexion MOYEN ⚠ EN COURS

OWASP : A7 — Authentication Failures

CVSS v3.1 : 5.9 (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)

Description : L'endpoint `POST /login` ne limitait pas le nombre de tentatives de connexion, permettant théoriquement des attaques par force brute sur les mots de passe.

Impact : Risque de compromission de comptes utilisateurs par force brute. Ne compromet pas directement les tokens Facebook Login (gérés par Meta).

Plan de correction : Implémentation du middleware `Laravel throttle:5,15` sur la route de login (5 tentatives / 15 minutes). Correction prévue avant le 30 juin 2026.

Risque résiduel : **Faible** — ne permet pas d'accès non autorisé aux données Facebook Login. Les tokens Meta sont validés côté serveur via l'API Graph indépendamment.

F-005 Endpoint CMS sans validation stricte du type MIME pour les uploads MOYEN ✓ CORRIGÉ

OWASP : A3 — Injection / File Upload

CVSS v3.1 : 4.7 (AV:N/AC:H/PR:L/UI:R/S:C/C:L/I:L/A:N)

Description : L'endpoint d'upload d'images du CMS (/admin/cms/upload) validait l'extension du fichier côté client uniquement, sans vérification du type MIME côté serveur.

Correction : Ajout de `$request->file('image')->getMimeType()` avec whitelist stricte (`image/jpeg`, `image/png`, `image/webp`).

Stockage hors webroot pour les fichiers non-image.

Date correction : 10 mai 2026

F-006 Firebase Admin SDK — utilisation de l'API v1 legacy MOYEN ⚠️ **PLANIFIÉ**

OWASP : A6 — Vulnerable and Outdated Components

CVSS v3.1 : 4.3 (AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:L)

Description : Les notifications push Firebase utilisent l'API FCM v1 legacy (dépréciée). Google a annoncé la fin de support de cette version.

Impact : Risque de perte de fonctionnalité notifications push. N'affecte pas la sécurité des données utilisateurs.

Plan de correction : Migration vers FCM HTTP v1 API avec authentification OAuth2 via service account. Correction prévue avant le 31 juillet 2026.

F-007 Headers de sécurité HTTP partiellement absents (CSP, HSTS sub-domains) FAIBLE ✓ **CORRIGÉ**

OWASP : A5 — Security Misconfiguration

CVSS v3.1 : 3.7 (AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

Description : L'en-tête Content-Security-Policy était absent. Le header Strict-Transport-Security ne couvrait pas les sous-domaines.

Correction : Ajout de CSP restrictive dans la configuration Nginx. HSTS avec includeSubDomains; preload. X-Frame-Options, X-Content-Type-Options ajoutés.

Date correction : 15 mai 2026

F-008 Logging des erreurs insuffisant (DSN Sentry non configuré en production) FAIBLE ⚠️ **PLANIFIÉ**

OWASP : A9 — Security Logging and Monitoring Failures

CVSS v3.1 : 2.7 (AV:N/AC:H/PR:H/UI:N/S:U/C:N/I:N/A:L)

Description : Le DSN Sentry n'était pas configuré sur le serveur de production, réduisant la visibilité sur les erreurs et tentatives d'intrusion.

Plan de correction : Configuration du DSN Sentry dans le fichier .env de production. Alertes email sur les erreurs critiques activées. Correction prévue avant le 15 juin 2026.

F-009 Token d'accès Mapbox exposé dans les logs de déploiement FAIBLE ⚠️ **PLANIFIÉ**

OWASP : A2 — Cryptographic Failures

CVSS v3.1 : 3.1 (AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N)

Description : Le token Mapbox publique (côté frontend, non secret) apparaissait dans les logs de déploiement rsync. Bien que ce token soit public par nature, sa rotation n'était pas documentée.

Plan de correction : Rotation du token Mapbox et documentation du processus de renouvellement annuel. Correction prévue avant le 30 juin 2026.

4. VÉRIFICATIONS SPÉCIFIQUES — DONNÉES FACEBOOK LOGIN

Un focus particulier a été porté sur la sécurité du flux Facebook Login et la protection des données reçues de Meta :

Vérification	Résultat	Détail
Validation du token Facebook côté serveur	✓ Conforme	Token validé via Facebook Graph API avant création de session
Données Facebook stockées chiffrées en transit	✓ Conforme	HTTPS TLS 1.2+ sur tous les endpoints, HSTS activé
Isolation des données par utilisateur (IDOR)	✓ Corrigé (F-001)	Correction déployée le 28 avril 2026
Absence de partage de données Facebook à des tiers	✓ Conforme	Aucune transmission à services tiers non autorisés
Droit à l'effacement des données Facebook	✓ Conforme	Endpoint de suppression de compte disponible
Tokens Facebook non persistés en clair	✓ Conforme	Seuls l'ID utilisateur et l'email sont stockés après validation
Absence de credentials Facebook dans le code source	✓ Conforme	App Secret dans .env uniquement, hors dépôt Git

5. AUDIT DES DÉPENDANCES PHP

Commande exécutée le 2 juin 2026 : composer audit

Résultat	Détail
Aucune CVE critique détectée	Toutes les dépendances Laravel 10 sont à jour. Aucune vulnérabilité connue dans les packages utilisés.

Résultat complet : No security vulnerability advisories found. — composer audit, 2 juin 2026.

6. CONCLUSION ET DÉCLARATION

L'audit de sécurité réalisé entre le 15 avril et le 2 juin 2026 sur l'environnement backend de BantuDelice a permis d'identifier et de corriger **toutes les vulnérabilités de niveau élevé**, notamment la faille IDOR qui aurait pu permettre un accès non autorisé aux données de profil liées à des comptes Facebook Login.

Vulnérabilités critiques ou élevées non corrigées : AUCUNE.

Les 4 éléments restants (2 moyens, 2 faibles) ont un plan de correction avec date d'échéance avant le 31 juillet 2026 et ne présentent pas de risque d'accès non autorisé aux données transmises par la plateforme Meta.

Le prochain audit de sécurité complet est planifié pour **janvier 2027**, conformément à la politique de sécurité annuelle de BantuDelice.

Responsable technique — BantuDelice

Date : 3 juin 2026

Rapport BDL-PENTEST-2026-001
bantudelice.cg | gess198@gmail.com
Brazzaville, République du Congo